

TP ÉVALUÉ

Audit, Intrusion et Sécurisation

"Shadow Network"

Module	Cybersécurité & Administration Système
Niveau	BTS SIO SISR - 1ère année
Support technique	Kali Linux (Attaquant) & Debian (Cible)
Durée	3h30
Notation	/20

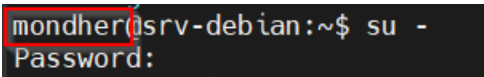
OBJECTIFS PÉDAGOGIQUES

À l'issue de ce TP, vous serez capable de :

- Réaliser un audit de sécurité basique avec nmap
- Mener une reconnaissance passive sur un serveur web
- Exploiter une élévation de privilèges sous Linux
- Réaliser une cryptanalyse simple (hash MD5, Base64)
- Analyser des logs système pour identifier une intrusion
- Appliquer des mesures de durcissement SSH

LIVRABLE

Vous devrez fournir un document format .docx ou .pdf en prenant soin d'inscrire votre nom, prénom, date et toutes les preuves de votre travail. Les captures d'écran doivent être lisibles avec votre nom ou prénom comme utilisateur, lorsque c'est possible, comme l'image ci-contre.



```
mondher@srv-debian:~$ su -  
Password:
```

1. CONTEXTE DE LA MISSION

L'entreprise **SIO-CORP** soupçonne une intrusion sur son serveur de sauvegarde. Un ancien technicien mécontent aurait laissé des indices sur le serveur web et une archive chiffrée contenant des données confidentielles.

Votre mission se déroule en deux phases :

1. **Phase Offensive** : Retrouver l'accès au serveur et déchiffrer le message secret.
2. **Phase Défensive** : Analyser les logs pour identifier l'attaquant et durcir la sécurité du serveur.

2. PRÉPARATION DE LA CIBLE (DEBIAN)

⚠ IMPORTANT : À réaliser sur la VM Debian en tant que **root** AVANT de commencer l'audit.

2.1 Installation et correctifs

Exécutez les commandes suivantes sur Debian :

```
export PATH="/usr/local/sbin:/usr/sbin:/sbin:$PATH"

wget -qO-
https://gist.githubusercontent.com/Dermou77/a38d215300acc342d8bbc7d425c9f04e/
raw/setup_tp.sh | DEBIAN_FRONTEND=noninteractive bash
```

2.2 Configuration de l'indice Web

```
echo "Serveur de sauvegarde SIO-CORP" > /var/www/html/index.html

echo -e "User-agent: *\nDisallow: /config_secret/\nIndice: Utilisateur =
ciso_student" > /var/www/html/robots.txt
```

2.3 Vérification

Notez l'adresse IP de la machine (commande : `ip a`) puis basculez sur **Kali Linux**.

PARTIE 1 : INTRUSION ET ANALYSE (10 POINTS)

Étape 1 : Reconnaissance réseau (2 points)

Objectif : Identifier les services actifs sur la machine cible.

Tâche :

- Scannez la cible avec la commande : `nmap` (vous pouvez utiliser le flag `-sV`)
- Identifiez les services HTTP (port 80) et SSH (port 22)

 **Livrible** : Capture d'écran montrant les services HTTP (80) et SSH (22).

Étape 2 : Recherche d'indices (2 points)

Objectif : Collecter des informations via le serveur web.

Tâche :

- Accédez à `http://[IP_CIBLE]/robots.txt` via le navigateur de Kali

- Relevez l'identifiant utilisateur (Username) mentionné dans l'indice

 **Livable :** Capture d'écran du fichier robots.txt avec l'identifiant trouvé.

Étape 3 : Accès et Élévation de Privilèges (3 points)

Objectif : Accéder au système et obtenir les droits administrateurs en procédant à une attaque par « Brute force » avec la commande Hydra pour retrouver le mot de passe.

Tâche :

- Brute Force SSH : * Le dictionnaire rockyou.txt étant trop volumineux, créez un dictionnaire personnalisé nommé `pass_tp.txt` contenant quelques mots de passe courants ainsi que celui de la cible.

```
echo -e 'admin\n123456\npassword\nroot\nPassword123!' > pass_tp.txt
```

- Utilisez Hydra pour trouver le bon mot de passe.

```
hydra -l ciso_student -P pass_tp.txt ssh://[IP_CIBLE]
```

 **Livable :** Capture d'écran du avec le mot de passe écrit en vert.

- Connectez-vous en SSH

```
ssh ciso_student@[IP_CIBLE]
```

- Le fichier secret est dans `/opt/backup/secret_part1.txt`
- Utilisez `su -` ou `sudo -i` pour obtenir les droits root et lire le fichier

 **Conseil :** Le mot de passe root est le même que celui de l'utilisateur.

 **Livable :** Capture d'écran du contenu du fichier `secret_part1.txt` avec le Hash MD5.

Étape 4 : Cryptanalyse et Code Final (3 points)

Objectif : Casser le hash MD5 et décoder le message final.

Tâche :

- Cassez le Hash MD5 en utilisant *CrackStation* (<https://crackstation.net>) ou *John the Ripper*
- Dans le dossier personnel de `ciso_student`, décompressez `archive.zip` avec le mot de passe trouvé
- Décodez le message Base64 contenu dans `enigme.txt`

 **Conseil :** Pour décoder Base64 : `base64 -d enigme.txt`

 **Livable :** Capture d'écran du message final décodé.

PARTIE 2 : FORENSICS ET SÉCURISATION (10 POINTS)

Étape 5 : Analyse des traces (Forensics) (3 points)

Objectif : Identifier l'intrusion dans les logs système.

Tâche :

- En tant que root sur Debian, analysez les logs de connexion

```
journalctl -t sshd -n 50
```

- Identifiez l'heure exacte de la connexion SSH réussie et l'adresse IP source

 **Conseil :** Cherchez les lignes contenant "Accepted password" ou "session opened"

 **Livable :** Capture d'écran de la ligne de log correspondante avec l'heure et l'IP source surlignées.

Étape 6 : Durcissement du service SSH (4 points)

Objectif : Appliquer des mesures de sécurisation pour SSH.

Tâche :

- Modifiez le fichier `/etc/ssh/sshd_config` pour :
 1. Changer le port 22 par le port 2222 : `Port 2222`
 2. Désactiver la connexion root directe : `PermitRootLogin no`
- Redémarrez le service

```
systemctl restart ssh
```

- Testez la connexion depuis Kali

```
ssh -p 2222 ciso_student@[IP_CIBLE]
```

 **ATTENTION :** N'oubliez pas le `-p 2222` pour le nouveau port !

 **Livable :** Deux captures d'écran :

1. Modifications dans `/etc/ssh/sshd_config`
2. Test de connexion réussie sur le port 2222

Étape 7 : Nettoyage et sécurisation Web (3 points)

Objectif : Supprimer les traces de l'intrusion et les comptes compromis.

Tâche :

- Modifiez `/var/www/html/robots.txt` pour supprimer la ligne contenant l'indice utilisateur

- Supprimez l'utilisateur compromis

```
userdel -r ciso_student
```

- Vérifiez que le dossier `/home/ciso_student` a bien été supprimé

```
ls -la /home/
```

ou

```
grep "ciso_student" /etc/passwd
```

 **Livrable :** Capture d'écran montrant que le dossier `/home/ciso_student` a disparu.

BARÈME DE NOTATION

Critère	Points	Obtenu
PARTIE 1 : Intrusion et Analyse	10	
Étape 1 : Reconnaissance réseau	2	
Étape 2 : Recherche d'indices	2	
Étape 3 : Accès et Élévation de Privilèges	3	
Étape 4 : Cryptanalyse et Code Final	3	
PARTIE 2 : Forensics et Sécurisation	10	
Étape 5 : Analyse des traces (Forensics)	3	
Étape 6 : Durcissement du service SSH	4	
Étape 7 : Nettoyage et sécurisation Web	3	
TOTAL	/20	

CONSEILS ET RECOMMANDATIONS

- **Documentez chaque étape** avec des captures d'écran claires et lisibles
- **Nommez vos fichiers** de manière explicite (ex : Etape1_Nmap.png)
- **Gérez votre temps** : Partie 1 (1h30) - Partie 2 (1h30) - Vérifications (30min)
- **En cas de blocage** : Relisez attentivement les consignes et les conseils, vérifiez vos commandes
- **Contexte éthique** : Ce TP simule un audit légal et autorisé. Toute utilisation de ces techniques en dehors d'un cadre légal est interdite.

Bon courage !